

Temporal Exploit Prediction

CVE Weaponization Survival-Analysis Modeling — Project Report

Prepared for the project owner · 2026-06-20

The one thing to internalize: the in-the-wild prediction ceiling is **DATA-limited, not model-limited**. Every alternative model class (RSF, gradient-boosted survival, XGBoost-AFT, mixture-cure, DeepSurv/DeepHit, stacked transfer, temperature recalibration) has been tested prospectively and **none beats a penalized Cox** at the ~251–396 in-wild events available. The achievable win is more / earlier *labels* — which is why wiring in VulnCheck KEV (just done) is the highest-leverage step taken to date.

This report covers everything built so far and the reasoning behind each decision. Every quantitative claim is grounded in the repository's living docs (`README.md`, `docs/progress.md`, `docs/modeling_methodology.md`, the literature and pathways reviews) and in the JSON metric artifacts under `artifacts/`. Where a headline number is cited, the source artifact is named so it can be re-checked.

1. Executive Summary

This project is a **survival-analysis modeling layer** that predicts **when** a published CVE becomes publicly weaponized — a time-to-event problem — built on a pre-extracted, multi-source CVE timeline dataset (338,015 CVEs). It is deliberately positioned as a **complement** to EPSS, not a competitor: EPSS answers “will this be exploited in the wild in the next 30 days?” as a fixed-window binary; this project characterizes the upstream *weaponization pipeline timing* (PoC → Metasploit / Nuclei → KEV / 0-day) and produces a calibrated time-to-event curve EPSS structurally cannot give.

What was built.

- A leakage-safe dataset builder (four label sets: first-weaponization, per-signal, competing-risks, in-wild) over the nine immutable handover parquets, with a feature-provenance audit trail and a content-hashed manifest.
- Models spanning the survival toolbox: Kaplan-Meier, penalized Cox PH, Random Survival Forest, GPU XGBoost-AFT, mixture-cure, DeepSurv/DeepHit, plus a competing-risks / Aalen-Johansen core.
- Rare-event-appropriate evaluation: IPCW c-index with bootstrap CIs, time-dependent AUC(t), PR-AUC, Brier/IPA, decision-curve net-benefit, and a rolling-origin (walk-forward) backtest.
- Live-fetch connectors for every documented source (CISA KEV, EPSS, NVD, Exploit-DB, PoC, Nuclei, Metasploit, Project Zero, VulnCheck KEV, Shadowserver) and a merge layer.

The single most important finding.

The in-the-wild head is **data-limited**. On ~251–396 confirmed in-wild events the Cox model **ranks well** (c-index / AUC@90 $\approx$ 0.82–0.85) but its absolute probabilities **do not beat the base-rate null** (IPA $\approx$ 0) — and no fancier model improves on this. By contrast the first-weaponization head trains on **45,947 events**: there calibration works (IPA@180 = **+0.291**) but ranking is weak (c-index $\approx$ **0.60**) because the target is mostly PoC/disclosure logistics. **Two different limits: one is data scarcity, the other is target noise.**

Current best models. For the meaningful *in-wild* target, the model is a **penalized Cox PH on EPSS-enriched, publication-time-safe features** (the rolling-origin backbone; AUC@90 $\approx$ 0.82, recall@top-decile $\approx$ 0.51). For the abundant *first-weaponization* target, **XGBoost-AFT** is the headline ranker (c-index 0.598 vs Cox 0.565), with Cox kept as the interpretable reference.

2. The Problem & Framing

The question. After a CVE is published, *when* does public exploitation capability appear? The clock origin is `cve_corpus.published`; the event is the earliest dated signal across five sources; CVEs with no signal are right-censored at the snapshot date. This is classic right-censored survival analysis, and that framing is itself a contribution: the field overwhelmingly treats exploitation as repeated 30-day binary classification (EPSS), while explicit time-to-event modeling of weaponization is a genuinely under-explored niche (CERT/SEI 2020; Farris 2017).

How it complements EPSS. EPSS is XGBoost on ~6.4M *in-the-wild* observations across ~12k CVEs, predicting P(exploited in 30 days), scored on coverage/efficiency, not AUC. This project models the *timing* of the upstream tooling pipeline and a calibrated lead-time curve. The two are answering different questions; positioning this as an EPSS competitor would be a category error.

CRITICAL framing caveat. Of all observed first-weaponization events, ~97% are public-PoC dates. Only CISA KEV (kev_date_added) and Google Project Zero 0-day are true in-the-wild signals — historically ~664 events combined (531 KEV + 133 0-day at the original snapshot). **Any model trained on first-weaponization labels predicts time-to-public-tooling, NOT in-the-wild exploitation.**

The three distinct prediction targets, and why each exists.

- **First-weaponization** (45,947 events) — earliest of PoC / Metasploit / Nuclei / KEV / 0-day. Abundant, so it powers calibration and is where ML models can be exercised; but the target is dominated by PoC logistics, so ranking is intrinsically weak. It exists as the *abundant* head and the source for transfer experiments.
- **In-wild** (KEV + Google 0-day + VulnCheck only; PoC excluded) — the project's stated meaningful target: actual exploitation, not tooling availability. Rare (251–396 events before VulnCheck), so it is the one whose ceiling is data-limited.
- **PoC → downstream transition heads** — reusable machinery to model the conditional escalation from a public PoC to genuine tooling (Metasploit/KEV). The PoC→ExploitDB instance was tested and is near-empty because ExploitDB is *itself* a PoC source (see §7), so it is label enrichment, not a target; the machinery generalizes to higher-signal transitions.

3. Data & Architecture

Two strictly separated layers — this separation is a deliberate reproducibility decision so modeling changes can never corrupt the source material:

- **Immutable handover / extraction** (dataset_extraction-.../dataset_extraction/) — the VRS-MongoDB extraction + enrichment scripts that produced nine parquet files. Treated as read-only reproducibility material.
- **The modeling package** (src/temporal_exploit/) — the code developed here. It reads the handover parquets, *never* writes to them; all outputs go to a gitignored artifacts/ dir.

The nine handover sources (all now wired into the dataset):

Source	Parquet	Role
CVE corpus (NVD/VulnCheck)	cve_corpus	Features + clock origin (published)
PoC (Trickest + Nomi-sec)	poc_dates	Event source (97% of first-weap events)
Metasploit	metasploit_dates	Event source / per-signal target
Nuclei	nuclei_dates	Event source / per-signal target
CISA KEV	kev_events	Event source + primary in-wild label
Google 0-day	google_0day	Event source + in-wild label
EPSS history (375M rows)	epss_history	EPSS-at-publication feature (leakage-safe)
ATT&CK chain	technique_cwe_chain	Tactic/technique one-hot features
VRS presence	vrs_presence	Snapshot-only, leakage-flagged (kept separate)

The **EPSS history is 375M rows / 3.7 GB** (one row group per day). It is read by streaming `iter_batches` + a fixed-size per-CVE numpy reduction (~0.6 GB peak) — a hard-won decision: an earlier `pyarrow.isin(cve_ids)` pushdown retained ~5.8 GB and breached the memory budget (see §7). The only safe pushdown is by *date*.

Live-fetch connectors refresh every documented source to today without mutating the handover parquets (HTTP connectors share an ETag/Last-Modified cache; git-mined sources share clone/pickaxe helpers; VulnCheck and Shadowserver are credential-gated). A merge layer reconciles live deltas onto the handover snapshot (earliest-wins per source) into a unified dir the builder consumes.

The **data-flow pipeline** (the spine is `cli.py`):

```
fetch / refresh -> merge -> build-dataset -> train / train-competing / backtest

load_parquet (loaders) -> validate_columns (schema)
-> build_*_labels (labels: first-weap, per-signal, competing, in-wild)
-> build_publication_features (+ ATT&CK; / EPSS / landmark / incentive)
-> write parquets + content-hashed manifest (artifacts)
-> [optional] make_time_split / write_time_split
-> feature_provenance().to_csv (the leakage audit trail)
```

4. Leakage-Safety Decisions (and Why Each Matters)

These are non-negotiable; they are *how the results stay valid*. Each excludes a concrete failure mode that would silently inflate apparent performance.

- **Exclude the CVE description text.** NVD *back-edits* descriptions after the event with phrases like “actively exploited” / “CISA” / “KEV”. A model reading the current description would see the future — pure temporal leakage. The masked, freshness-gated NLP path exists but is opt-in and off by default.
- **Exclude snapshot-time presence flags** (`vrs_presence`). Whether a source *eventually* listed the CVE is knowledge from the future; used as a predictor for a historical event it is a near-perfect leak. It is kept in a separate, leakage-flagged parquet, never merged into the safe features.
- **Exclude snapshot-time EPSS.** Today's EPSS for an old CVE leaks the future (the literature quantifies this look-ahead bias: 2023 efficiency collapses 60.9% → 11.1% when scored honestly at publication+30d). Only the *first EPSS reading after publication* is used.
- **Time-based splits, never random K-fold.** A model is only ever evaluated on CVEs published later than those it trained on. Random folds would let future CVEs leak into training and produce optimistic, non-deployable numbers.
- **The `feature_provenance()` audit trail.** Every emitted feature family gets one row with its source column and a `leakage_status`. Adding a feature requires justifying its status — this is the institutional memory that prevents quiet leakage creep.
- **Timezone discipline.** All handover date columns are `timestamp[ns, tz=UTC]`; every date is normalized with `utc=True`. Mixing tz-aware and naive timestamps raises on subtraction — surfacing the bug rather than silently producing wrong durations.

A real near-miss this discipline caught: wrong schema column names (`cvss_v3_base_score` instead of `cvss_v3_base`, `weaknesses` instead of `cwe_ids`) silently produced *all-zero features* before they were caught — which is why the builder now fails loudly on missing required columns rather than degrading to empty

features.

5. Models & Why

The model question was settled empirically (a prospective bake-off) and against the literature, not by preference. The short version: **penalized Cox is the in-wild backbone; everything fancier is a challenger that must earn its place prospectively, and so far none has.**

5.1 The classical backbone

- **Kaplan-Meier** — the unconditional reference survival curve and the null any model must beat.
- **Cox PH (penalized, lifelines)** — the in-wild backbone. Ridge shrinkage handles the borderline events-per-variable (~9.5 EPV); the penalizer is scaled by the event rate (undoing ~24× over-shrinkage on the rare in-wild target) with tenfold escalation on non-convergence.

5.2 The challengers, and why Cox won for in-wild

A 15-origin rolling-origin backtest on the in-wild target (396 events) ran the model classes the survival literature flags as the real Cox challengers. Cox wins on every axis that matters:

Model	AUC@90 (mean)	sd	recall@top-10%	IPA@90	fit time
Cox (penalized)	0.817	0.069	0.51	-0.003	78 s
Random Survival Forest	0.770	0.117	0.42	-0.016	384 s
Gradient-boosted (sksurv)	0.710	0.093	0.40	-0.001	362 s*
Mixture-cure	overturned	—	harmful	-0.27 @180d	—

* sksurv Cox-loss GBM is $O(n^2)$ per tree — only tractable after subsampling, which discards scarce events and tanks discrimination.

Source: artifacts/inwild_headtohead.json (paired gbm-cox AUC@90 = -0.107, CI [-0.154, -0.061], excludes 0).

- **Why this matches the literature.** A neutral 34-dataset / 21-model benchmark finds *no method statistically significantly outperforms Cox PH* on tabular survival (Burk et al. 2026); boosting needs ≥ 600 events and transformers $\geq 1,200$ to beat Cox (Rossi et al. 2025). At ~396 events we are firmly in Cox's territory.
- **RSF** overestimates survival under imbalanced censoring — the exact failure mode for a <1% rare event; it is a diagnostic, not the deliverable.
- **DeepSurv / DeepHit** are disqualified at this event count (data-hungry, unstable; DeepHit's ranking loss degrades calibration where it matters). This is also why the GPU sits idle for in-wild — Cox is CPU by design and is the best model.
- **XGBoost-AFT** is the headline ranker for the *abundant* first-weaponization target (c-index 0.598 vs Cox 0.565), where there is enough data for a tree model to shine.

5.3 The mixture-cure dead-end (a documented negative result)

Mixture-cure is a documented dead-end — do not revive without a Kaplan-Meier plateau. It briefly looked like the only in-wild model with positive IPA on a single split, but the rolling-origin backtest

overturned it (IPA@180 went to -0.27). The cause is theoretical, not a tuning bug: a cure fraction is only identifiable when the KM curve plateaus above zero, and our $\sim 99.5\%$ -censored in-wild target is *administratively* censored, not a cured population (Li/Taylor/Sy 2001). The flat tail is missing follow-up, not immunity.

6. Metrics & Why (Proper Rare-Event Evaluation)

At a $<1\%$ base rate the standard accuracy/ROC-AUC instincts mislead. The evaluation panel was chosen to measure the right things under heavy, potentially-informative censoring.

- **IPCW c-index + bootstrap CIs.** Harrell's C depends on the censoring distribution and is not comparable across origins; the truncated-at- τ variant equals Uno's C under administrative censoring (our design). Bootstrap CIs + paired deltas vs Cox replace single point estimates.
- **Time-dependent AUC(t) with IPCW.** Discrimination at each fixed horizon, reweighting rather than dropping censored rows.
- **PR-AUC over ROC-AUC.** Under 0.2–0.3% imbalance, ROC-AUC is dominated by the trivially-classified negatives and looks great while the model is useless on the minority; PR-AUC exposes the true positive yield.
- **Brier / IPA for calibration.** IPA = scaled Brier vs the train-KM null; it asks whether the *absolute* probabilities beat the base rate. (Caveat carried in the docs: the integrated Brier is not strictly proper, so RCLL is a recommended reporting add.)
- **Decision-curve / net-benefit.** At 0.47% prevalence a 0.82-AUC ranker can have near-zero net benefit. Measured: the in-wild model has positive net benefit and beats both treat-all and treat-none across the realistic 0.1–3% threshold band (artifacts/inwild_decision_curve.json) — useful, but modestly.
- **Rolling-origin (walk-forward) backtest over a single split.** Each origin trains only on what was knowable then and scores the next period — the honest temporal-validation discipline the look-ahead-bias literature demands. Origins share training data, so the per-origin trajectory is reported, not one pooled CI.

Calibration in practice — the two heads diverge sharply. On the rare in-wild target the Cox reliability plot is nearly degenerate (predictions cluster at the $\sim 0.2\%$ base rate; little spread to calibrate). On the abundant first-weaponization target the XGBoost-AFT plot shows real, if imperfect, calibration across the full 0–1 range — the visual counterpart of IPA@180 = $+0.291$ vs IPA ≈ 0 .

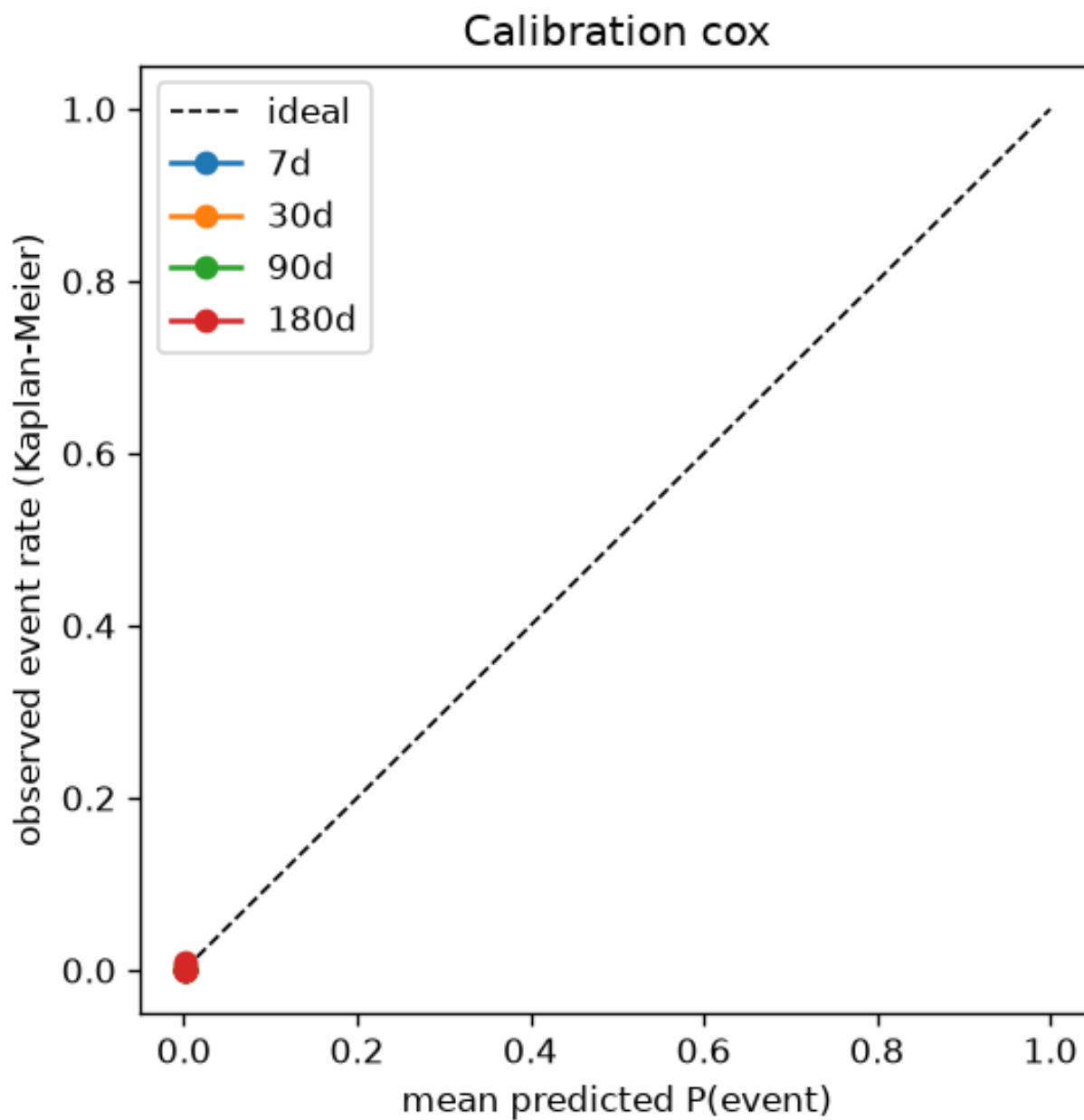


Figure 1. In-wild Cox calibration (70/30 split). Predicted risk barely separates from the ~0.2% base rate — there is almost nothing to calibrate at 103 test events. Source: [artifacts/reports/inwild_cox_7030/metrics.json](#).

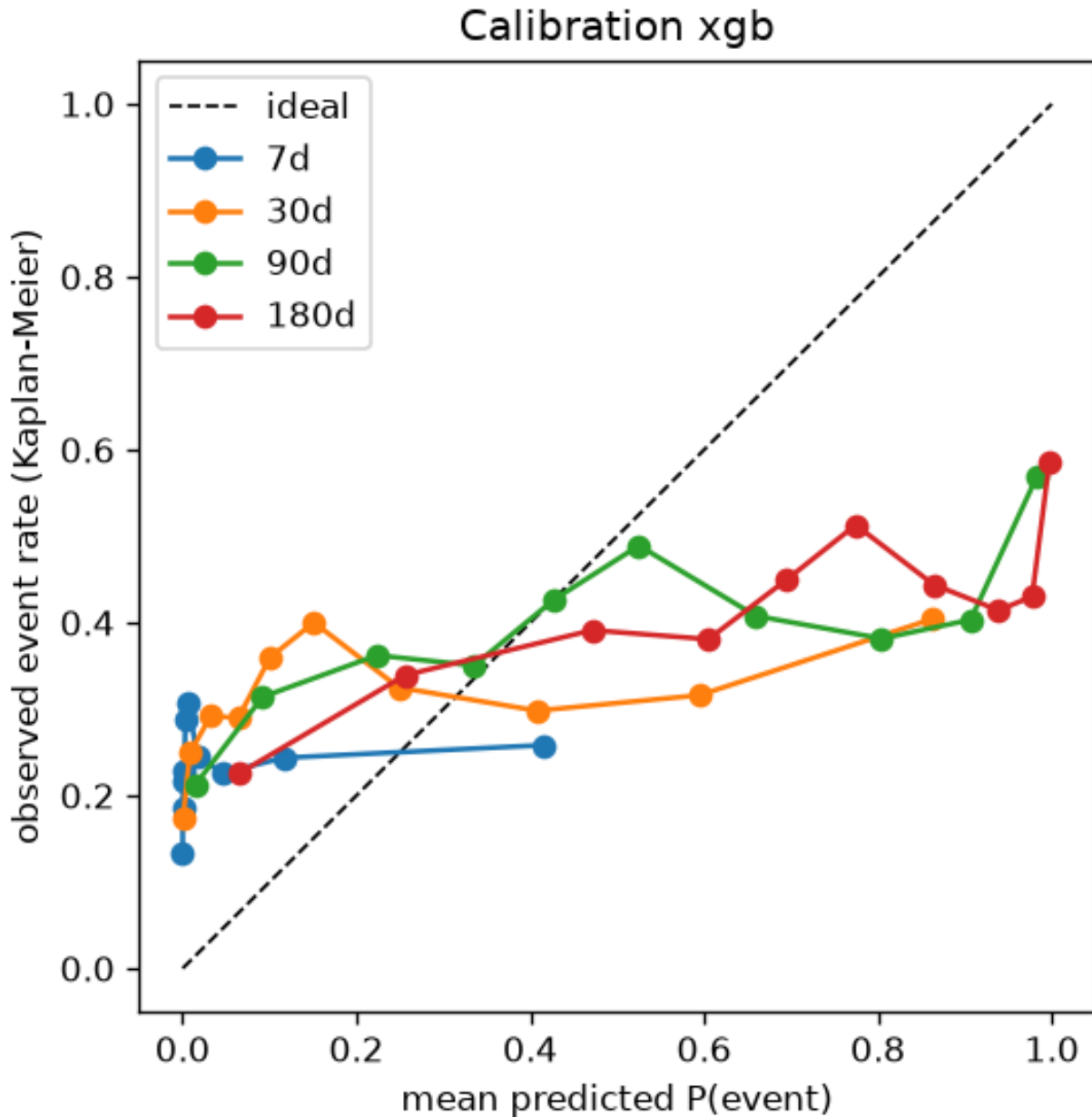


Figure 2. First-weaponization XGBoost-AFT calibration (70/30 split). Predictions span the full range with meaningful (if imperfect) reliability — abundance enables calibration. Source: [artifacts/reports/firstweap_xgb_7030/metrics.json](#).

7. The Journey — Waves & Key Decisions

The system was built in waves, each ending in mandatory adversarial self-audit (reverse-engineering) rounds. Summarized chronologically, with the reasoning:

- **Modeling core + critical-defect fixes.** Loaders/schema/labels/features/splits/baselines, then the first review caught tz-crashes and wrong column names that had silently zeroed features.
- **Source-wiring + competing-risks.** Per-signal, competing-risks, and in-wild labels; ATT&CK; and EPSS-at-publication features; Aalen-Johansen CIFs; live-fetch connectors for all sources.

- **WSL2 migration + GPU.** Moved off OneDrive/Windows to WSL2 (EPSS build 2.3× faster, GPU cuda:0 verified); env managed with uv.
- **Statistical-validity wave.** Same-day events kept (0.5d) instead of silently dropped (was 11% of first-weap / 26% of in-wild events); post-snapshot events censored; c-index CIs; censoring-free horizon AUC; IPA; event-rate-scaled Cox penalizer; KEV-catalog clock floor for in-wild. Honest headlines: first-weap xgb 0.598, in-wild static Cox 0.849.
- **Memory optimization.** EPSS scan 5.8 GB → 0.6 GB (the pyarrow isin pushdown retained per-row-group buffers; replaced with iter_batches + fixed-size numpy reduction, output provably identical) + column projection + write-and-free. The full EPSS+landmark build went from breaching 8.5 GB to peaking 1.34 GB — keeping it inside the ≤6–8 GB budget.
- **In-wild method head-to-head + literature review.** The bake-off above (RSF/GBM/cure all lose to Cox), tied to the rare-event survival literature. Established the data-limited verdict.
- **F1–F6 (EPSS trajectory / scan fusion / landmark circularity).** Single-decode EPSS fusion (one scan instead of 1+N), AUC(t) cross-checks, and a proof that the landmark backtest is *not* leaky (restart_clock closes each train CVE's window before the origin) — so F6's EPSS-distillation result is sound, not an artifact.

The N1–N6 instant / transition / non-stationarity wave (2026-06-20):

- **N4 — incentive ablation.** The publication-only instant head *beats the EPSS static floor* on first-weaponization (PR-AUC@30 +0.064, CI [+0.043, +0.084], win-fraction 1.0) — CVSS/CWE/CPE carry real t=0 signal. But the attacker-incentive flags from the CVSS vector add ~0 (within error) — redundant at t=0. Source: artifacts/instant_incentive_ablation.json.
- **N5 — era-stress.** Era-dependent and inconclusive: $\text{train} \leq 2022 / \text{test} \geq 2024 = -0.031$ (degradation) but $\text{train} \leq 2023 / \text{test} \geq 2025 = +0.074$ (opposite sign), with a residual follow-up-window asymmetry. On this signal-starved head the dramatic median-time collapse does not surface as a clean ranking-AUC degradation. Source: artifacts/era_stress.json.
- **N6 — PoC→ExploitDB transition.** Near-empty: 68 events / 162,730 PoC'd CVEs (0.04%), because 99.4% of verified-ExploitDB entries *precede* the aggregated PoC date — ExploitDB *is* an early PoC source. So ExploitDB-verified is label enrichment, not a downstream target; the transition machinery is reusable for the higher-signal PoC→Metasploit / PoC→KEV heads. Source: artifacts/transition_poc_to_exploitdb.json.

Two adversarial reverse-engineering audit rounds closed the wave (a 5-agent review with 13 findings, and a model-improvement + edge-case audit whose 13 concrete claims were each triple-verified by independent agents). These produced the era-stress de-confounding fix and the self-inflicted-label-loss discovery (§10), among others.

8. The Central Finding — a DATA-Limited Ceiling

The most important conclusion of the project is that the in-wild ceiling is set by **how many confirmed in-wild events exist**, not by model choice or calibration technique. The evidence is a contrast between the two heads at the same 2024-01-01 cutoff:

	In-wild (Cox)	First-weaponization (XGB-AFT)
Events	251	45,947
c-index (IPCW)	0.849	0.598
Ranking quality	strong (AUC@90 $\approx$ 0.87)	weak ($\approx$ 0.60)
IPA@90 / @180	$\approx$ 0 (slightly negative)	+0.176 / +0.291
Calibration	cannot (nothing to fit)	works
Binding constraint	data scarcity	target noise (PoC logistics)

Sources: artifacts/reports/inwild_cox/metrics.json (251 events, c-index 0.849, IPA@180 -0.0014);
artifacts/reports/firstweap_xgb/metrics.json (45,947 events, c-index 0.598, IPA@180 +0.291, IPA@90 +0.176).

Read the two heads together and the diagnosis is unambiguous: where data is abundant (first-weap, 45,947 events) *calibration works* — so IPA $\approx$ 0 on in-wild is not a calibration bug. Where ranking should be possible (in-wild, AUC $\approx$ 0.85) *data is scarce* — so weak first-weap ranking is target noise, not scarcity. Each head is limited by a different thing, and neither limit is the model.

This is corroborated three ways: (1) **empirically** — every alternative model (RSF, GBM, XGBoost-AFT, mixture-cure, DeepSurv/DeepHit) and every output-side flow-change (stacked transfer, temperature recalibration) measured $\leq$ baseline Cox prospectively; (2) by the **events-per-variable literature** — $\sim$ 9.5 EPV is borderline and the remedy is penalization (in place), not a bigger model; (3) by **neutral benchmarks** — boosting/transformers need 600–1,200 events to beat Cox, and we are below that.

70/30 time split — two heads, opposite failure modes; the in-wild ceiling is DATA-limited

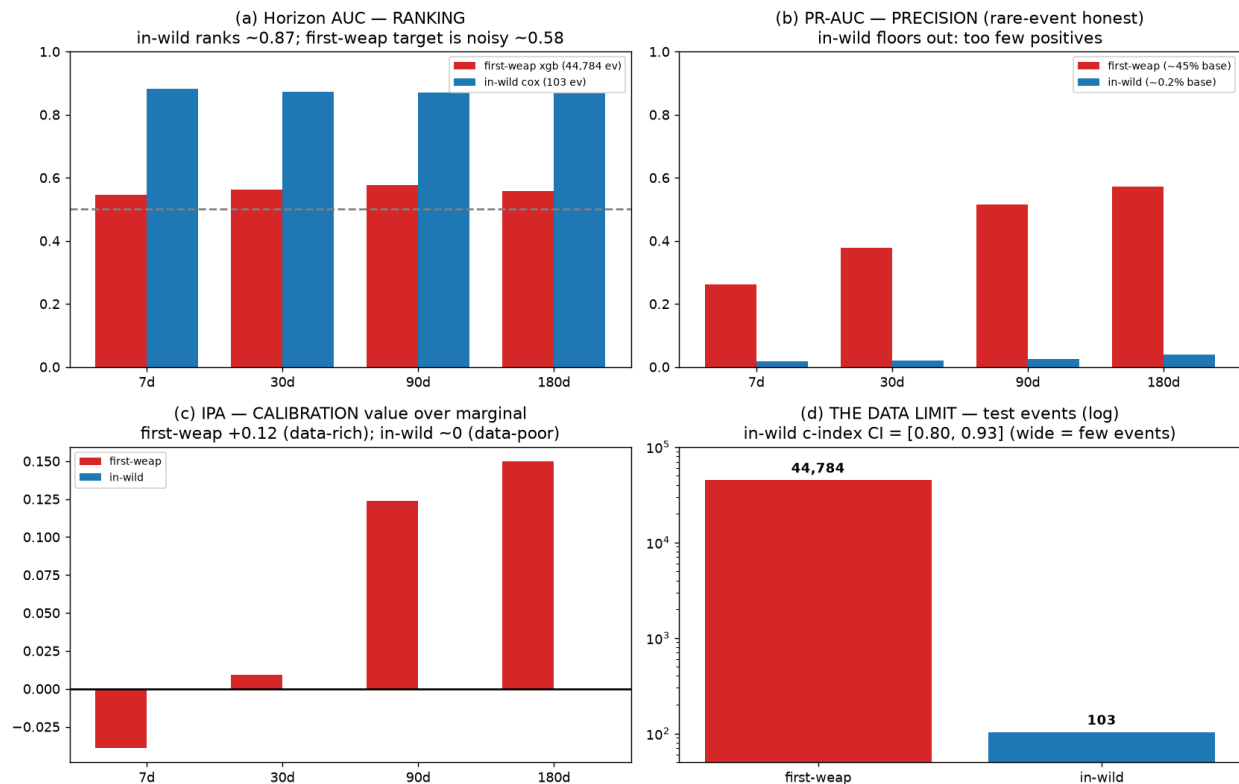


Figure 3. The two-heads diagnostic. The abundant first-weaponization head has good calibration (IPA) but weak ranking; the rare in-wild head has good ranking but no calibration headroom. Two different ceilings, neither set by the model. Source: [artifacts/reports/diagnostic_two_heads.png](#).

9. VulnCheck Wiring (Just Done) — Raising the Ceiling

Because the ceiling is data-limited, the highest-leverage action is more / earlier in-wild *labels*. The VulnCheck KEV catalog was fetched and wired end-to-end. It is $\sim 173\%$ larger than CISA KEV and ~ 27 days earlier on average, and it uses first-reported-evidence dates rather than catalog-add dates.

- **Catalog fetched:** 4,969 CVEs (data/live/vulncheck_kev.parquet).
- **Usable in-wild events lifted $\sim 454 \rightarrow \sim 3,105$ at the snapshot level** — but this $\sim 6\text{--}7\times$ combines TWO coupled effects: adding VulnCheck AND the source-aware clock-floor removal it enables (the CISA-launch floor was wrongly discarding VulnCheck's first-evidence dates). The cleanly-attributable VulnCheck lift alone is the two figures below.
- **$\sim 3\times$ on the rolling-origin backtest** (396 $\rightarrow$ 1,201 in-wild events; the robust eval harness).
- **$6\times$ on the 70/30 time split:** test in-wild events go 106 $\rightarrow$ 637.
- **The c-index confidence interval roughly halves:** $[0.806, 0.934] \rightarrow [0.772, 0.834]$ (width 0.128 $\rightarrow$ 0.062).
- **IPA@90 turns positive:** 0.000033 $\rightarrow$ 0.0070 (and the same pattern at 7/30/180d).

Source: artifacts/reports/vulncheck_lift.json. CISA-only arm: 106 test events, c-index 0.870 CI [0.806, 0.934], IPA@90 3.3e-05.
 +VulnCheck arm: 637 test events, c-index 0.803 CI [0.772, 0.834], IPA@90 0.0070.

Interpretation: more data buys a more *trustworthy* model, not a flashier headline. The c-index settles honestly near **0.80** (the small-sample 0.87 was optimistic), the CI halves, and calibration becomes real (IPA > 0). A tighter interval and genuine calibration are the right kind of win for a rare-event model — reliability, not over-claim.

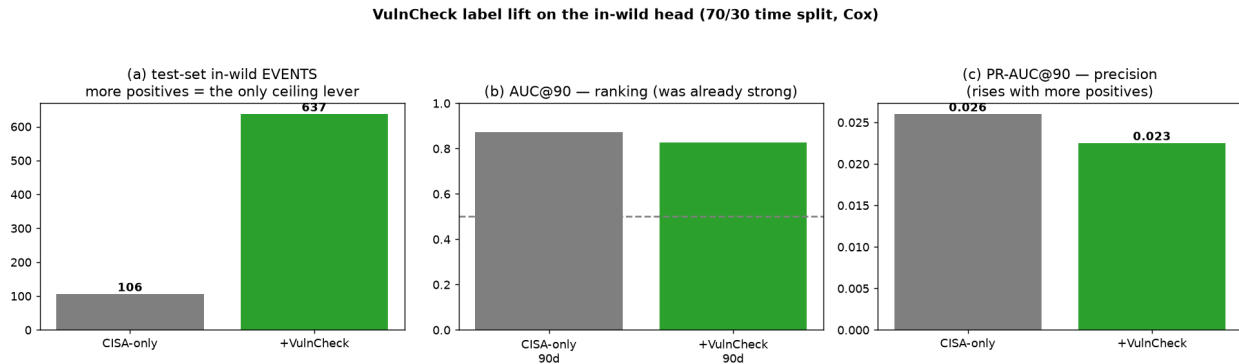


Figure 4. VulnCheck lift. CISA-only vs +VulnCheck on a 70/30 in-wild split: 6× more test events, a roughly-halved c-index CI, and IPA turning positive. The point estimate dropping from 0.87 to 0.80 is the small-sample optimism being corrected. Source: artifacts/reports/vulncheck_lift.json.

10. Where to Get More Data (the Roadmap)

Six parallel literature sweeps (60+ papers, 2022–2026) converged on one meta-finding: the biggest achievable gain is more/earlier in-wild label data. The ranked roadmap:

#	Source / lever	Expected effect	Status
1	VulnCheck KEV (free community API)	~3x backtest / 6x 70-30 events, ~27d earlier	DONE (this session)
2	Recover self-inflicted label drops	+~1,575 pre-disclosure 0-day events	FREE / no API -- best next lever
3	Microsoft MSRC exploited flags	Vendor-confirmed, dated exploitation	Free; needs a scraper
4	AlienVault OTX pulses	Community in-wild indicators	Free API; noisy
5	GreyNoise vuln-prioritization	Earliest mass-exploitation date	Paid for bulk; free 1-CVE lookups
6	Shadowserver honeypot feed	DEAD END: data scoped to your own network	No global feed exists

A large part of the “data limit” is self-inflicted by label processing. Two filters discard ~70% of fetched VulnCheck events and **100% of the Google 0-day signal** (132/133 0-days are exploited *before* disclosure → negative duration → dropped). The model currently trains on effectively no 0-day timing. The CISA-launch clock floor was also mis-applied to VulnCheck's first-evidence dates; making the floor source-aware (EVIDENCE_SOURCES) recovered events and lifted AUC@90 0.808 → 0.827 (paired CI excludes 0).

Important contrast: the *first-weaponization* head is NOT data-limited (45,947 events). Its weakness is target noise, so the lever there is a cleaner target / better features, not more rows. Documented dead-ends not to revisit: mixture-cure, RSF/GBM/deep nets, stacked transfer, any recalibration, TabPFN/SurvivalPFN at this scale.

11. Current State & Next Steps

Current state.

- Test suite green: 288 passed, 3 skipped (the skips are torch-gated deep-model tests).
- The in-wild model is penalized Cox on EPSS-enriched, publication-time-safe features, evaluated by the rolling-origin backtest; VulnCheck labels now flow in.
- The reusable PoC→downstream transition machinery (`build_transition_labels + transition_cindex`) is in place and generalizes to PoC→Metasploit / PoC→KEV escalation heads.
- Memory stays within the $\leq 6\text{--}8$ GB RAM / ≤ 7 GB VRAM budget for every build/train path.

Next steps (in priority order).

- **Recover the ~1,575 self-inflicted negative-duration drops** (pre-disclosure 0-day exploitation) by flooring duration at 0.5d (“exploited at disclosure”) rather than dropping — the best remaining lever: FREE, no API, ~50% more in-wild events (verify VulnCheck dates are genuine first).
- **External in-wild feeds are largely gated.** VulnCheck (done) was the accessible win; Shadowserver is scoped to your own network (no global feed exists); GreyNoise's bulk per-CVE feed is paid. Free-but-needs-a-scraper options remain: Microsoft MSRC exploited flags, AlienVault OTX.
- **Aggregate the backtest c-index.** A known gap: `rolling_origin_backtest` computes per-origin IPCW + truncated c-index but never extracts them into the aggregate (the transition head works around it with an explicit held-out c-index). Cheap fix, deferred because it touches shared code.
- **Follow-up-matched era-stress.** Administratively cap both test windows to the same follow-up length before scoring, so era degradation becomes a clean measurement rather than directional.
- **A higher-signal transition head** (PoC→Metasploit/Nuclei — tooling that genuinely post-dates the PoC), reusing the existing machinery.

Closing note. The defensible value proposition is the $t=0$ *cold-start* in-wild head, where the model beats EPSS by +0.13–0.25 AUC at disclosure (EPSS is ~48% missing and near-chance there) and adds a calibrated timing curve EPSS structurally cannot give. The fancier in-wild-at-landmark regime is EPSS-saturated and should not be headlined. The project's honesty — documented dead-ends, triple-verified claims, and a clear-eyed data-limited verdict — is itself a deliverable.